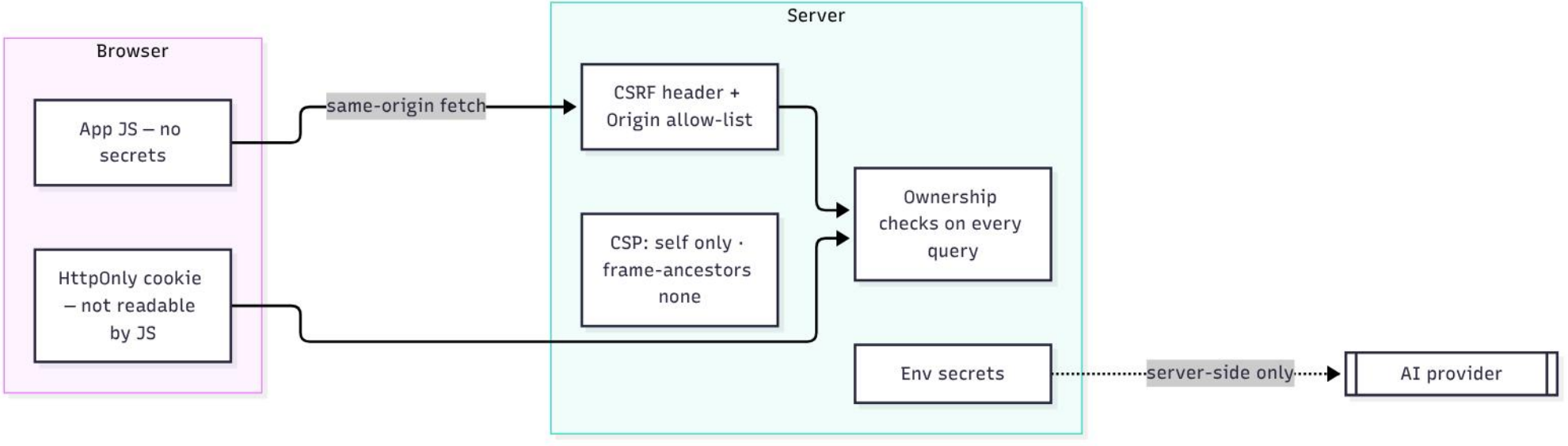
Browser
App JS — no secrets
HttpOnly cookie — not readable by JS
same-origin fetch
Server
CSRF header + Origin allow-list
CSP: self only · frame-ancestors none
Ownership checks on every query
Env secrets
server-side only
AI provider